

Circular sobre protección de datos de pacientes — versión 2

Departamento de Calidad

Circular interna — Protección de datos personales de pacientes (actualización)

Documento en revisión. Dirigido a: todo el personal de Clínica Delos.

1. Objeto

Esta circular actualiza las directrices internas sobre protección de datos personales de pacientes, incorporando las novedades normativas derivadas de la interpretación de la AEPD publicada en su Guía sobre tratamientos de datos en el ámbito sanitario (2024) y las observaciones de la última auditoría de cumplimiento.

Las disposiciones de esta circular complementan y, en lo que resulten contrarias, prevalecen sobre la circular de marzo de 2024.

2. Periodo de conservación actualizado

Tras consulta con el servicio jurídico externo y a la vista de la doctrina reciente de la AEPD, se propone ampliar el periodo de conservación de las historias clínicas:

Los datos contenidos en la historia clínica se conservarán durante un periodo mínimo de **10 años** desde la fecha del último episodio asistencial, duplicando el periodo anterior de 5 años. Esta ampliación se fundamenta en:

- La recomendación de la Guía AEPD 2024, que señala que el periodo mínimo de la Ley 41/2002 (5 años) es un suelo, no un techo, y que los responsables del tratamiento deben evaluar si periodos más largos están justificados.
- La necesidad de conservar datos para posibles reclamaciones de responsabilidad patrimonial sanitaria, cuyo plazo de prescripción puede extenderse hasta 15 años en determinados supuestos.
- Las obligaciones de conservación derivadas de la investigación clínica retrospectiva y los estudios de farmacovigilancia.

Nota importante: esta propuesta de ampliación está pendiente de aprobación formal por la dirección general y de consulta previa al Delegado de Protección de Datos. Hasta su aprobación, el periodo vigente sigue siendo de 5 años.

3. Nuevas categorías de datos

Se incorporan al registro de actividades de tratamiento las siguientes categorías de datos, no contempladas expresamente en la circular anterior:

- **Datos biométricos:** imágenes faciales para la verificación de identidad en el sistema de cita previa digital.
- **Datos de geolocalización:** derivados del uso de la app móvil del centro para la gestión de citas y recordatorios.

- **Datos de dispositivos médicos conectados:** registros de dispositivos IoT utilizados en la monitorización remota de pacientes crónicos.

El tratamiento de estas categorías requiere una evaluación de impacto en protección de datos (EIPD) que está en proceso de elaboración.

4. Transferencias internacionales

Se informa de que determinados proveedores tecnológicos utilizados por Clínica Delos tienen sus servidores principales en la Unión Europea, pero realizan transferencias puntuales a Estados Unidos para servicios de soporte técnico. Estas transferencias se amparan en las cláusulas contractuales tipo aprobadas por la Comisión Europea.

Los proveedores afectados son:

- Sistema de gestión de citas (servidores en Irlanda, soporte en EE.UU.).
- Plataforma de telemedicina (servidores en Alemania, soporte en EE.UU.).
- Servicio de almacenamiento en la nube para imágenes diagnósticas (servidores en Francia y Países Bajos).

5. Medidas técnicas adicionales

Se proponen las siguientes medidas técnicas adicionales al marco de seguridad vigente:

- **Cifrado en reposo:** todos los datos de salud almacenados en la HCE se cifrarán con AES-256. Implementación prevista para el segundo trimestre de 2025.
- **Doble factor de autenticación (2FA):** obligatorio para el acceso remoto a la HCE. Ya implementado para accesos VPN; pendiente de extensión al portal web.
- **Registros de acceso mejorados:** auditoría completa de accesos a historias clínicas con retención de logs durante 2 años. Los accesos anómalos generan alertas automáticas al DPD.
- **Anonimización automática:** los datos utilizados para investigación se anonimizarán mediante técnicas de k-anonimato y perturbación diferencial antes de su extracción del sistema.

6. Procedimiento de ejercicio de derechos ampliado

Se amplía el mecanismo de ejercicio de derechos de los pacientes:

- **Canal presencial:** solicitud en el mostrador de atención al paciente con identificación mediante DNI/NIE.
- **Canal telemático:** formulario en el portal del paciente con identificación mediante certificado digital o Cl@ve.
- **Canal postal:** solicitud dirigida al DPD, Clínica Delos, Avda. de la Constitución 42, 28001 Madrid.

El DPD acusará recibo en un plazo máximo de 5 días hábiles y resolverá en el plazo de un mes, prorrogable a dos meses en casos complejos.

7. Responsable de seguridad de la información

Se designa a D. Fernando Arrieta Godoy como Responsable de Seguridad de la Información (RSI), acumulando esta función con la de DPD. El RSI coordinará las auditorías de seguridad semestrales y la respuesta a incidentes de ciberseguridad.

8. Vigencia

Las disposiciones de esta circular entrarán en vigor una vez sean aprobadas por la dirección general. En su versión actual constituyen un borrador para revisión interna.

Documento en borrador · Departamento de Calidad · Clínica Delos · Sin fecha de firma.